Cheatsheet AZ-305 — 04 · Gobernanza: Policy, Blueprints, RBAC, management groups y tenants

1. Jerarquía y el muro del tenant

```
Tenant de Microsoft Entra ID  ← frontera absoluta: nada la cruza
└── Root management group
    └── Management groups (hasta 6 niveles)
        └── Suscripciones
            └── Resource groups
                └── Recursos
```

- **RBAC, Policy, Blueprints y management groups heredan hacia abajo** y **nunca cruzan tenants**.
- "Mínimo de asignaciones / management groups / definiciones" → **cuenta tenants** y aplica en el root MG de cada uno.
- Ejemplo: 2 tenants con 10 + 5 suscripciones → Network Contributor con **2 asignaciones** (una por root MG).
- Los **resource groups** no limitan la asociación técnica entre recursos (un NSG en RG2 puede asociarse a una subnet en RG1); solo son ciclo de vida, RBAC y Policy scope. La suscripción y la región sí limitan.
- **Tags**, no resource groups, para agrupar por dimensión de negocio (departamento, centro de coste). Un recurso solo puede estar en un RG.

2. Azure Policy: efectos

Efecto	Qué hace	Recursos nuevos	Recursos existentes	Remediation task	Identidad necesaria
Deny	Bloquea la creación / actualización	✓ bloquea	Marca no conforme	✗	—
Audit	Solo registra no cumplimiento	✓ registra	✓ registra	✗	—
AuditIfNotExists	Audita si falta un recurso relacionado	✓	✓	✗	—
Append	Añade campos / tags al crear; **deniega si hay conflicto**	✓	✗	✗	—
Modify	Añade / reemplaza / elimina **tags y propiedades** del recurso	✓	✓	✓	Managed identity + **Contributor**
DeployIfNotExists (DINE)	Despliega una **plantilla ARM** si falta algo (sub-recurso, extensión, diagnostic setting)	✓	✓	✓	Managed identity + rol del despliegue
Disabled	Desactiva sin borrar	—	—	—	—
EnforceOPAConstraint / EnforceRegoPolicy	Solo add-on de **Kubernetes/AKS** (Gatekeeper/OPA, Rego)	—	—	—	—

- Tags heredados del RG, nuevos y existentes, con remediación → **Modify**.
- Habilitar TDE con plantilla, agente AMA, diagnostic settings → **DeployIfNotExists**.
- Solo al crear y sin remediar → Append.
- Remediación: **managed identity** (no service principal) con el **mínimo rol** (Contributor para tags; nunca User Access Administrator, que gestiona RBAC).
- Evaluación: al asignar, al cambiar un recurso y **cada 24 h**; bajo demanda solo con **CLI (az policy state trigger-scan) / PowerShell / REST**, no desde el portal.
- Alertas de no cumplimiento → diagnostic setting a Log Analytics + alerta de tipo **Log**.
- Policy ≠ RBAC: Policy gobierna configuraciones; RBAC gobierna permisos. Policy no puede asignar roles.
- Policy a nivel de management group con **exclusiones** para suscripciones concretas.
- Un **Initiative** agrupa definiciones para asignarlas juntas.

3. Azure Blueprints (en retirada, sustituido por Template Specs / Deployment Stacks)

Elemento	Dónde se crea	Cuántos	Se cuenta por
Management group	Uno por tenant (mínimo)	= tenants	Tenants
Blueprint definition	En el management group (para reutilizar) o en una suscripción	= jerarquías donde reutilizar	Tenants
Blueprint assignment	**Por suscripción** destino	= suscripciones destino	Suscripciones

- Artefactos: resource groups, plantillas ARM, **role assignments**, policy assignments.
- Ejemplo East (Sub1, Sub2) / West (Sub3, Sub4): **2 MG · 2 definiciones · 4 asignaciones**.
- "Minimize definitions" → definir en el **root MG** de cada tenant. "Assignments" → una por suscripción.
- Para RBAC + Policy + estructura repetible a escala → Blueprints (o Bicep + Deployment Stacks).

4. RBAC

Concepto	Detalle de examen
Owner	Todo + gestionar asignaciones. Necesario para **cambiar el directorio de una suscripción**
Contributor	Todo salvo RBAC. Suficiente para remediar tags, crear un Recovery Services vault
Reader	Solo lectura
User Access Administrator	Solo gestiona RBAC
Network Contributor	Redes; aplicar en el root MG de cada tenant
Roles custom	Definir en el **management group** para reutilizar en todas las suscripciones; DataActions para plano de datos (blobs, files)
Global Administrator + "Access management for Azure resources"	**Elevate access**: User Access Administrator en / ; para suscripciones sin ningún Owner. Vía PIM y revertir después
Site Recovery Contributor / Operator	Operar replicación / ejecutar failover; ninguno crea el vault (eso Contributor)
Resource-context vs workspace-context (Log Analytics)	Resource-context: ver solo logs de los recursos donde tienes RBAC; recomendado hub-spoke
Resource locks	CanNotDelete / ReadOnly; aplican incluso a Owners; se heredan
Resource Guard	En **otra suscripción/tenant**; exige rol allí para operaciones críticas de backup (anti-ransomware, separation of duties)

5. Cost Management y organización

- **Tags** + Cost Management → informes por departamento; Policy (Modify) garantiza que existan.
- **Budgets** con alertas; **Azure Advisor** recomendaciones (no actúa).
- **Management groups** para estructurar EA / divisiones; **subscriptions** como límite de facturación y cuota.

6. Árbol de decisión

```
¿Qué pide?
├─ Bloquear una configuración ..... Policy Deny
├─ Solo detectar ..... Policy Audit
├─ Añadir/corregir tags o propiedades, nuevos y existentes ..... Policy Modify + managed identity + Contributor
├─ Desplegar algo que falta con plantilla ARM ..... Policy DeployIfNotExists
├─ Gobernanza en clúster AKS ..... Policy add-on (OPA/Rego)
├─ Permisos para todas las suscripciones con mínimo esfuerzo ... RBAC en root MG (uno por tenant)
├─ Reutilizar rol custom en muchas suscripciones ..... Definir en MG
├─ Paquete repetible RBAC + Policy + estructura ..... Blueprints (def. en MG, assignment por sub)
├─ Impedir borrar un RG incluso a Owners ..... Resource lock / Policy Deny delete
├─ Suscripción sin administradores tras mover de tenant ..... Global Admin + elevate access
├─ Mover suscripción a otro tenant ..... Owner en la suscripción
├─ Proteger backups de administradores comprometidos ..... Resource Guard en otra suscripción
└─ Agrupar recursos por departamento para reportar ..... Tags (+ Policy)
```

7. Señales → respuesta

Enunciado	Respuesta
"minimum number of role assignments" + management groups	Número de tenants
"minimum management groups / blueprint definitions"	Número de tenants
"minimum blueprint assignments"	Número de suscripciones destino
"remediation tasks" + "tags"	Modify, managed identity, Contributor
"remediation tasks" + "ARM template"	DeployIfNotExists
"trigger on-demand compliance scan"	Azure CLI / PowerShell / REST
"change the directory of a subscription"	Owner
"no accounts have permissions on the subscription"	Global Administrator (elevate access)
"create and manage the Recovery Services vault"	Contributor
"group resources by department" + "compliance reports"	Tags + Azure Policy
"ransomware" + "require a role in another subscription"	Resource Guard
"MSP manages other tenants"	Lighthouse

8. Errores a evitar

1. Asignar Blueprints en el management group → las **asignaciones son por suscripción**; en el MG va la **definición**.
2. Append para recursos existentes → no remedia; Modify.
3. Service principal para remediación → managed identity.
4. User Access Administrator para escribir tags → Contributor.
5. Creer que un MG o un rol cruza tenants.

6. Reorganizar resource groups para agrupar por departamento → tags.
7. Buscar el botón de "evaluar ahora" en el portal → no existe.